ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA MẠNG MÁY TÍNH VÀ TRUYỀN THÔNG

Nguyễn Tài Phú - 23521185
Trần Minh Nhật - 23521099
Châu Hoàng Phúc - 23521191

ĐỒ ÁN CHUYÊN NGÀNH

Triển khai CIS Benchmark trên hệ thống Linux

Linux CIS Benchmark Implementation

GIẢNG VIÊN HƯỚNG DẪN
Thạc sĩ Trần Thị Dung

TP. HỒ CHÍ MINH, NĂM 2026

Mục lục

Mục lục **i**

1 Tổng quan hệ thống **1**

1.1 Mục tiêu triển khai 1

1.1.1 Mục tiêu chính 1

1.1.2 Lợi ích mong đợi 1

1.2 Phạm vi triển khai 1

1.2.1 Ubuntu Server 24.04 LTS 1

1.2.2 CIS Level 1 Benchmark 2

1.3 Kiến trúc hệ thống 2

1.3.1 Kiến trúc tổng thể 2

1.3.2 Luồng hoạt động 2

1.3.3 Ansible 3

1.3.4 Lynis 3

1.3.5 OpenSCAP 3

2 Phương pháp triển khai **4**

2.1 Quy trình tổng thể 4

2.1.1 Scan → Hardening → Validate → Report 4

2.2 Phương pháp tiếp cận 4

2.2.1 Manual Configuration 4

2.2.2 Automation bằng Ansible 4

2.3 Thiết kế hệ thống Ansible 5

2.3.1 Inventory 5

2.3.2 Playbooks 5

2.3.3 Roles 5

3 Triển khai **6**

3.1 Phase 1 – Core Security Foundations 6

3.1.1 System Information Gathering 6

3.1.2 Package Management 9

3.1.3 OpenSCAP Integration 13

3.1.4 Lynis Security Audit . . . 16
3.2 Phase 2 – Filesystem & System Hardening . . . 19
3.2.1 Filesystem Security . . . 19
3.2.2 SUID/SGID Audit Report Creation . . . 25
3.2.3 System Settings . . . 28
3.2.4 ASLR Configuration . . . 30
3.3 Phase 3 – Password Policy Enhancement . . . 32
3.3.1 Basic Password Policy . . . 32
3.4 Phase 4 – SSH Hardening . . . 38
3.4.1 SSH Configuration . . . 38
3.5 Phase 5 – Services Configuration . . . 44
3.5.1 Service Management . . . 44
3.6 Phase 6 – Network & Firewall . . . 44
3.6.1 Network Security . . . 44
3.7 Phase 7 – Logging & Audit . . . 45
3.7.1 Audit System Configuration . . . 45
3.8 Phase 8 – Compliance & Reporting . . . 45
3.8.1 Comprehensive Reporting . . . 45

4 Tổng kết **47**
4.1 Kết quả đạt được . . . 47
4.2 Hạn chế . . . 47
4.3 Hướng phát triển . . . 47

Chương 1

Tổng quan hệ thống

1.1 Mục tiêu triển khai

1.1.1 Mục tiêu chính

Nghiên cứu này tập trung vào việc xây dựng một quy trình tự động hóa để nâng cao bảo mật cho hệ thống Ubuntu Server 24.04 LTS theo tiêu chuẩn CIS Level 1 Benchmark. Các mục tiêu chính bao gồm:

- Tự động hóa quá trình kiểm tra và hardening bảo mật
- Đảm bảo tuân thủ 100% các yêu cầu CIS Level 1
- Giảm thiểu sai sót do con người trong quá trình cấu hình
- Tạo ra quy trình có thể tái sử dụng cho các hệ thống khác

1.1.2 Lợi ích mong đợi

Việc triển khai tự động hóa bảo mật mang lại nhiều lợi ích thực tiễn:

- Tiết kiệm thời gian và nguồn lực quản trị
- Tăng tính nhất quán giữa các hệ thống
- Dễ dàng theo dõi và báo cáo trạng thái bảo mật
- Nhanh chóng phát hiện và khắc phục các lỗ hổng

1.2 Phạm vi triển khai

1.2.1 Ubuntu Server 24.04 LTS

Ubuntu Server 24.04 LTS là phiên bản LTS (Long Term Support) mới nhất, cung cấp:

- Hỗ trợ dài hạn đến năm 2029
- Kernel Linux 6.8 với nhiều cải tiến bảo mật
- Tích hợp sẵn các công cụ bảo mật hiện đại
- Cộng đồng hỗ trợ lớn và tài liệu phong phú

Việc chọn phiên bản này đảm bảo tính ổn định và bảo mật lâu dài cho hệ thống sản xuất.

1.2.2 CIS Level 1 Benchmark

CIS (Center for Internet Security) Level 1 Benchmark là tập hợp các quy tắc bảo mật cơ bản:

- 188 đề xuất cấu hình cho Ubuntu Server 24.04
- Phù hợp cho môi trường production
- Không ảnh hưởng đến chức năng hoạt động của hệ thống
- Được công nhận rộng rãi trong ngành công nghiệp

1.3 Kiến trúc hệ thống

1.3.1 Kiến trúc tổng thể

Hệ thống được thiết kế theo mô hình 3 lớp:

1. **Lớp kiểm tra**: Sử dụng Lynis và OpenSCAP để quét và đánh giá
2. **Lớp hardening**: Ansible playbooks thực hiện các thay đổi cấu hình
3. **Lớp báo cáo**: Tạo báo cáo tuân thủ và đề xuất cải thiện

1.3.2 Luồng hoạt động

Quy trình hoạt động của hệ thống:

- Bước 1: Quét hệ thống hiện tại để xác định trạng thái
- Bước 2: Áp dụng các quy tắc hardening tự động
- Bước 3: Xác thực lại các cấu hình đã áp dụng
- Bước 4: Tạo báo cáo chi tiết về kết quả

1.3.3 Ansible

Ansible là công cụ tự động hóa mã nguồn mở được chọn vì:

- Agentless - không cần cài đặt agent trên máy mục tiêu
- YAML-based - dễ đọc và bảo trì
- Idempotent - đảm bảo kết quả nhất quán
- Hỗ trợ rộng rãi cho các module hệ thống

Ansible sẽ được sử dụng để:

- Cấu hình các tham số sysctl
- Quản lý file và permissions
- Cài đặt và cấu hình các dịch vụ
- Áp dụng các policy bảo mật

1.3.4 Lynis

Lynis là công cụ audit bảo mật mã nguồn mở:

- Hơn 200 test bảo mật khác nhau
- Hỗ trợ CIS Benchmark
- Cung cấp đề xuất cải thiện chi tiết
- Nhẹ và nhanh, không yêu cầu cài đặt phức tạp

1.3.5 OpenSCAP

OpenSCAP là bộ công cụ tuân thủ bảo mật của NIST:

- Hỗ trợ SCAP (Security Content Automation Protocol)
- Tích hợp với CIS Benchmark
- Khả năng xuất báo cáo theo nhiều định dạng
- Được sử dụng rộng rãi trong chính phủ Doanh nghiệp

Chương 2

Phương pháp triển khai

2.1 Quy trình tổng thể

2.1.1 Scan → Hardening → Validate → Report

Quy trình triển khai bảo mật được thiết kế theo chu trình 4 bước chính, đảm bảo tính toàn diện và có thể lặp lại. Mỗi bước có vai trò cụ thể và liên kết chặt chẽ với nhau để tạo ra một hệ thống bảo mật hoàn chỉnh.

Quy trình này bắt đầu từ việc đánh giá trạng thái hiện tại, tiếp theo là áp dụng các biện pháp hardening, sau đó xác thực kết quả và cuối cùng là tạo báo cáo chi tiết. Vòng lặp này giúp đảm bảo hệ thống luôn được cập nhật và tuân thủ các tiêu chuẩn bảo mật mới nhất.

2.2 Phương pháp tiếp cận

2.2.1 Manual Configuration

Cấu hình thủ công là phương pháp truyền thống trong quản trị hệ thống. Administrator trực tiếp thực hiện các thay đổi trên hệ thống thông qua command line hoặc giao diện đồ họa.

Phương pháp này có ưu điểm là linh hoạt và dễ kiểm soát từng bước, nhưng nhược điểm lớn là tốn nhiều thời gian, dễ xảy ra sai sót, và khó đảm bảo tính nhất quán giữa nhiều hệ thống khác nhau.

Đối với các hệ thống quy mô nhỏ, cấu hình thủ công vẫn có thể được áp dụng cho các tác vụ đặc thù yêu cầu sự can thiệp chuyên sâu.

2.2.2 Automation bằng Ansible

Ansible là công cụ tự động hóa mạnh mẽ giúp loại bỏ các thao tác thủ công lặp đi lặp lại. Với Ansible, chúng ta có thể định nghĩa toàn bộ quy trình hardening dưới dạng code, đảm bảo tính nhất quán và có thể tái sử dụng.

Ansible sử dụng YAML để định nghĩa các playbook, giúp administrator dễ dàng đọc, hiểu và chỉnh sửa. Khả năng idempotent của Ansible đảm bảo rằng việc chạy nhiều lần sẽ không gây ra các trạng thái không mong muốn.

Đặc biệt, Ansible hoạt động theo chế độ agentless, chỉ yêu cầu SSH và Python trên máy mục tiêu, giúp giảm thiểu sự phức tạp trong việc triển khai.

2.3 Thiết kế hệ thống Ansible

2.3.1 Inventory

Inventory là thành phần cơ bản của Ansible, dùng để định nghĩa danh sách các máy chủ mục tiêu. Inventory có thể được định nghĩa dưới dạng file INI, YAML, hoặc sử dụng dynamic inventory từ các nguồn như cloud providers.

Trong dự án này, inventory được cấu trúc theo nhóm máy chủ để dễ dàng quản lý và áp dụng các chính sách khác nhau cho từng nhóm. Mỗi nhóm có thể có các biến riêng biệt phù hợp với vai trò và yêu cầu bảo mật cụ thể.

Inventory cũng cho phép định nghĩa các biến toàn cục và biến riêng cho từng host, giúp linh hoạt trong việc cấu hình môi trường đa dạng.

2.3.2 Playbooks

Playbooks là tập hợp các task được định nghĩa theo thứ tự thực hiện. Mỗi playbook có thể chứa một hoặc nhiều play, mỗi play áp dụng cho một nhóm host cụ thể và thực hiện các task thông qua các module Ansible.

Playbooks trong dự án này được chia thành các chức năng chính: scanning, hardening, validation, và reporting. Mỗi playbook được thiết kế để có thể chạy độc lập hoặc kết hợp với nhau theo quy trình tổng thể.

Các playbook sử dụng conditional logic, handlers, và error handling để đảm bảo tính robust và khả năng phục hồi khi gặp lỗi.

2.3.3 Roles

Roles là cách tổ chức Ansible code theo cấu trúc module hóa, giúp tái sử dụng và bảo trì dễ dàng. Mỗi role có cấu trúc thư mục chuẩn gồm tasks, handlers, templates, files, vars, defaults, và meta.

Trong dự án này, các role được phân chia theo chức năng bảo mật: filesystem, network, services, users, logging, monitoring. Mỗi role chịu trách nhiệm về một lĩnh vực cụ thể của việc hardening bảo mật.

Cấu trúc role giúp dễ dàng mở rộng, cập nhật và chia sẻ giữa các dự án khác nhau, đồng thời đảm bảo tính nhất quán trong việc áp dụng các biện pháp bảo mật.

Chương 3

Triển khai

3.1 Phase 1 – Core Security Foundations

3.1.1 System Information Gathering

Mô tả: Thu thập thông tin chi tiết về hệ thống để đánh giá trạng thái bảo mật hiện tại và xác định các thành phần cần cấu hình. Quá trình này bao gồm việc kiểm tra phiên bản hệ điều hành, thông tin phần cứng, các dịch vụ đang chạy và cấu hình mạng.

Nội dung triển khai:

- Kiểm tra phiên bản hệ điều hành Ubuntu và kernel
- Thu thập thông tin phần cứng (CPU, RAM, disk)
- Liệt kê các dịch vụ đang chạy và cổng mở
- Kiểm tra cấu hình mạng và interface
- Xác định người dùng và nhóm hệ thống
- Kiểm tra các gói phần mềm đã cài đặt

Manual:

```
uname -a # Hiển thị thông tin kernel
lsb_release -a # Hiển thị phiên bản Ubuntu
df -h # Hiển thị thông tin disk
free -m # Hiển thị thông tin RAM
ps aux # Hiển thị các tiến trình đang chạy
netstat -tulpn # Hiển thị các cổng mở
ip addr show # Hiển thị cấu hình mạng
cat /etc/passwd # Hiển thị danh sách người dùng
```

Bảng 3.1.1: Lệnh thu thập thông tin hệ thống

Automation:

System Information Gathering Tasks:

```
- name: Gather kernel information
 command: uname -a
 register: kernel_info
 changed_when: false

- name: Gather Ubuntu version information
 command: lsb_release -a
 register: ubuntu_info

- name: Gather disk information
 command: df -h
 register: disk_info

- name: Gather memory information
 command: free -m
 register: memory_info

- name: Gather running processes
 command: ps aux
 register: process_info

- name: Gather open ports
 command: netstat -tulpn
 register: ports_info

- name: Gather network configuration
 command: ip addr show
 register: network_info

- name: Gather user information
```

```
  command: cat /etc/passwd
  register: user_info

- name: Save comprehensive system information to report
  copy:
  dest: /tmp/system_info_report.txt
  content: |
  === System Information Report ===
  Generated on: {{ ansible_date_time.iso8601 }}
```

Bảng 3.1.2: Ansible tasks cho system information gathering

Kết quả và đánh giá:

```
PLAY [Phase 1: Core Security Foundations] ******************************************************************************

TASK [Gathering Facts] *****************************************************************************************************
[WARNING]: Host '192.168.122.12' is using the discovered Python interpreter at '/usr/bin/python3.12', but future installa
e discovered. See https://docs.ansible.com/ansible-core/2.20/reference_appendices/interpreter_discovery.html for more inf
ok: [192.168.122.12]
[WARNING]: Host '192.168.122.5' is using the discovered Python interpreter at '/usr/bin/python3.12', but future installat
 discovered. See https://docs.ansible.com/ansible-core/2.20/reference_appendices/interpreter_discovery.html for more info
ok: [192.168.122.5]

TASK [phase_1/system_info : Gather system information] *****************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_1/system_info : Save system information to report] *********************************************************
[WARNING]: Deprecation warnings can be disabled by setting `deprecation_warnings=False` in ansible.cfg.
[DEPRECATION WARNING]: INJECT_FACTS_AS_VARS default to `True` is deprecated, top-level facts will not be auto injected af
.
Origin: /home/teifu142/ATE/UIT/NT542/cis-ubuntu/roles/phase_1/system_info/tasks/main.yml:10:14

 8   copy:
 9     dest: /tmp/system_info_report.txt
10     content: |
               ^ column 14

Use `ansible_facts["fact_name"]` (no `ansible_` prefix) instead.
```

Hình 3.1.1: System Information Gathering - Ansible Task Execution

- **Kết quả:** Thu thập thành công thông tin chi tiết hệ thống trên 2 server (192.168.122.5 và 192.168.122.12). Các file kết quả đã được lưu về controller với kích thước 39KB mỗi file, chứa thông tin đầy đủ về kernel parameters, cấu hình hệ thống, thông tin phần cứng và network.
- **Đánh giá:** Việc thu thập thông tin hệ thống thành công cung cấp cái nhìn tổng quan về trạng thái bảo mật hiện tại. Các thông tin thu thập được sẽ là cơ sở quan trọng cho các phase cài đặt và hardening tiếp theo.

3.1.2 Package Management

Mô tả: Cài đặt và cấu hình các gói phần mềm cần thiết cho bảo mật hệ thống. Đảm bảo hệ thống có các công cụ cơ bản để giám sát, phát hiện và phòng chống các mối đe dọa bảo mật.

Nội dung triển khai:

- Cập nhật hệ thống và các gói phần mềm
- Cài đặt các công cụ bảo mật cơ bản (fail2ban, ufw, auditd)
- Cài đặt công cụ giám sát hệ thống (sysstat, htop)
- Cài đặt công cụ quét lỗ hổng (nmap, lynis)
- Cấu hình repository và khóa GPG
- Xóa các gói phần mềm không cần thiết

Manual:

1. System Update:

```
sudo apt update # Cập nhật package lists
sudo apt upgrade -y # Nâng cấp hệ thống
sudo apt autoremove -y # Xóa packages không cần thiết
```

Bảng 3.1.3: Lệnh cập nhật hệ thống

2. Security Tools Installation:

```
sudo apt install fail2ban # Brute force protection
sudo apt install ufw # Uncomplicated Firewall
sudo apt install auditd # System auditing
sudo apt install rkhunter # Rootkit detection
sudo apt install chkrootkit # Additional rootkit detection
```

Bảng 3.1.4: Lệnh cài đặt công cụ bảo mật cơ bản

3. Monitoring and Scanning Tools:

```
sudo apt install sysstat # System statistics
sudo apt install htop # Process monitoring
sudo apt install nmap # Network scanning
sudo apt install lynis # Security auditing
sudo apt install aide # File integrity monitoring
```

Bảng 3.1.5: Lệnh cài đặt công cụ giám sát và quét

Automation:

Package Installation Automation:

```
- name: Update apt cache
 apt:
 update_cache: yes

- name: Upgrade system packages
 apt:
 upgrade: yes
 update_cache: yes

- name: Remove unnecessary packages
 apt:
 autoremove: yes

- name: Install basic security tools
 apt:
 name:
 - fail2ban
 - ufw
 - auditd
 state: present

- name: Install additional rootkit detection tools
 apt:
```

```
 name:
 - rkhunter
 - chkrootkit
 state: present

- name: Install monitoring and system tools
 apt:
 name:
 - sysstat
 - htop
 state: present

- name: Install network scanning and security auditing tools
 apt:
 name:
 - nmap
 - lynis
 - aide
 state: present

- name: Install PAM password quality module
 apt:
 name:
 - libpam-pwquality
 state: present
```

Bảng 3.1.6: Ansible tasks cho automated package installation

Kết quả và đánh giá:

```
TASK [phase_1/packages : Update apt cache] ***************************************************************************
changed: [192.168.122.5]
changed: [192.168.122.12]

TASK [phase_1/packages : Install security packages] ******************************************************************
ok: [192.168.122.5]
ok: [192.168.122.12]
```

Hình 3.1.2: Package Management - Security Tools Installation

- **Kết quả:** Cài đặt thành công các gói bảo mật cơ bản trên cả 2 server. Ansible playbook thực hiện 25 tasks trên server 192.168.122.12 và 22 tasks trên server 192.168.122.5, với 8 changes trên mỗi server. Các packages như fail2ban, ufw, auditd, lynis đã được cài đặt thành công.
- **Đánh giá:** Các công cụ bảo mật đã được cài đặt thành công, tạo nền tảng vững chắc cho các giai đoạn bảo mật tiếp theo. Cần cấu hình chi tiết các tools trong phase 2 để tối ưu hóa hiệu quả bảo mật.

3.1.3 OpenSCAP Integration

Mô tả: Tích hợp OpenSCAP - công cụ chuẩn hóa quét bảo mật theo NIST Security Content Automation Protocol (SCAP). Công cụ này hỗ trợ đánh giá tuân thủ các tiêu chuẩn bảo mật như CIS Benchmarks.

Nội dung triển khai:

- Cài đặt OpenSCAP scanner và utilities
- Kiểm tra phiên bản và các thông số kỹ thuật được hỗ trợ
- Tạo báo cáo thông tin về khả năng của OpenSCAP
- Lưu trữ kết quả về controller để phân tích

Manual:

1. OpenSCAP Installation:

```
sudo apt install openscap-scanner openscap-utils # Core packages
sudo apt install scap-security-guide # SCAP content
sudo apt install libopenscap8 # SCAP library
```

Bảng 3.1.7: Lệnh cài đặt OpenSCAP và dependencies

2. OpenSCAP Verification:

```
oscap -version # Kiểm tra phiên bản
oscap -version > /tmp/openscap_info.txt # Lưu thông tin
oscap -info /usr/share/xml/scap/ssg/content/ssg-ubuntu2204-xccdf.xml # Check content
```

Bảng 3.1.8: Lệnh kiểm tra và xác nhận OpenSCAP

3. SCAP Content Preparation:

```
wget https://raw.githubusercontent.com/ComplianceAsCode/content/master # Download content
oscap info ssg-ubuntu2204-xccdf.xml # Verify Ubuntu content
oscap xccdf eval -profile xccdf_org.ssgproject.content_profile_standard # Test scan
```

Bảng 3.1.9: Lệnh chuẩn bị SCAP content cho Ubuntu

Automation:

OpenSCAP Installation Automation:

```
- name: Install OpenSCAP core packages
 apt:
 name:
 - openscap-scanner
 - openscap-utils
 - libopenscap8
 state: present
 update_cache: yes

- name: Install SCAP content
 apt:
 name: scap-security-guide
 state: present

- name: Check OpenSCAP version
 command: oscap -version
 register: openscap_version
 changed_when: false

- name: Check SCAP content information
 command: oscap -info /usr/share/xml/scap/ssg/content/ssg-ubuntu2204-xccdf.xml
 register: openscap_content
 changed_when: false

- name: Save OpenSCAP report
 copy:
 content: |
 {{ openscap_version.stdout }}
 SCAP Content Information:
 {{ openscap_content.stdout | default('SCAP content not available') }}
```

```
dest: /tmp/openscap_scan_result.txt
```

Bảng 3.1.10: Ansible tasks cho OpenSCAP installation và verification

Kết quả và đánh giá:

```
TASK [phase_1/openscap : Install OpenSCAP] ***********************************************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_1/openscap : Check OpenSCAP version] *****************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_1/openscap : Display OpenSCAP information] ***********************************************************
ok: [192.168.122.12] => {
    "msg": "OpenSCAP installed successfully. Version: OpenSCAP command line tool (oscap) 1.3.9"
}
ok: [192.168.122.5] => {
    "msg": "OpenSCAP installed successfully. Version: OpenSCAP command line tool (oscap) 1.3.9"
}

TASK [phase_1/openscap : Create basic OpenSCAP info report] ******************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_1/openscap : Save OpenSCAP report] *******************************************************************
ok: [192.168.122.5]
ok: [192.168.122.12]
```

Hình 3.1.3: OpenSCAP Integration - Version Check and Capabilities

- **Kết quả:** Cài đặt thành công OpenSCAP version 1.3.9 trên cả 2 server. Công cụ hỗ trợ đầy đủ các tiêu chuẩn SCAP 1.3, XCCDF 1.2, OVAL 5.11.1 và các probe khác nhau. File thông tin chi tiết (4KB) đã được thu thập về controller.
- **Đánh giá:** OpenSCAP đã sẵn sàng để thực hiện các bài đánh giá bảo mật phức tạp. Cần bổ sung SCAP content cụ thể cho Ubuntu 24.04 để thực hiện CIS benchmark trong các phase tiếp theo.

3.1.4 Lynis Security Audit

Mô tả: Thực hiện audit bảo mật hệ thống bằng Lynis - công cụ quét bảo mật mạnh mẽ giúp phát hiện các lỗ hổng, lỗi cấu hình và các vấn đề bảo mật trong hệ thống Linux.

Nội dung triển khai:

- Cài đặt Lynis security audit tool
- Chạy quick scan để đánh giá nhanh trạng thái bảo mật
- Thu thập báo cáo chi tiết về các findings
- Lưu trữ kết quả audit về controller để phân tích

Manual:

1. Lynis Installation:

```
sudo apt install lynis # Cài đặt Lynis
sudo apt install curl # Download tool for updates
lynis show version # Verify installation
```

Bảng 3.1.11: Lệnh cài đặt và xác nhận Lynis

2. Lynis Audit Commands:

```
sudo lynis audit system # Full system audit
sudo lynis audit system -quick # Quick scan mode
sudo lynis audit system -pentest # Penetration testing mode
sudo lynis update info # Update Lynis database
```

Bảng 3.1.12: Lệnh thực hiện audit bảo mật với Lynis

3. Report Generation:

```
sudo lynis audit system > /tmp/lynis_audit_output.txt # Save full output
sudo lynis audit system -report-file /tmp/lynis_report.txt # Detailed report
cat /var/log/lynis.log # View audit log
grep "Warning" /tmp/lynis_report.txt # Extract warnings
```

Bảng 3.1.13: Lệnh tạo và xử lý báo cáo Lynis

Automation:

Lynis Security Audit Automation:

```
- name: Install curl for Lynis updates
 apt:
 name: curl
 state: present

- name: Install Lynis
 apt:
 name: lynis
 state: present
 update_cache: yes

- name: Show Lynis version
 command: lynis show version
 register: lynis_version
 changed_when: false

- name: Update Lynis database
 command: lynis update info
 register: lynis_update
 changed_when: false

- name: Run Lynis audit
 command: lynis audit system -quick
 register: lynis_output

- name: Save audit output
 copy:
 content: "{{ lynis_output.stdout }}"
 dest: /tmp/lynis_report.txt
```

```
- name: Create Lynis audit summary
 copy:
 dest: /tmp/lynis_audit_summary.txt
 content: |
 === Lynis Security Audit Summary ===
 Generated on: {{ ansible_date_time.iso8601 }}
 Lynis Version: {{ lynis_version.stdout | default('Unknown') }}
 Update Information: {{ lynis_update.stdout | default('No update info available')
}}
```

Bảng 3.1.14: Ansible tasks cho Lynis security audit automation

Kết quả và đánh giá:

```
TASK [phase_1/lynis : Install Lynis] ***********************************************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_1/lynis : Run Lynis audit] *********************************************************************
changed: [192.168.122.5]
changed: [192.168.122.12]

TASK [phase_1/lynis : Save audit output] *******************************************************************
changed: [192.168.122.12]
changed: [192.168.122.5]

TASK [phase_1/lynis : Create Lynis audit summary] ******************************************************
[DEPRECATION WARNING]: INJECT_FACTS_AS_VARS default to `True` is deprecated, top-level facts will not be auto injected aft
.
Origin: /home/teifu142/ATE/UIT/NT542/cis-ubuntu/roles/phase_1/lynis/tasks/main.yml:20:14

18   copy:
19     dest: /tmp/lynis_audit_summary.txt
20     content: |
               ^ column 14

Use `ansible_facts["fact_name"]` (no `ansible_` prefix) instead.

changed: [192.168.122.12]
changed: [192.168.122.5]
```

Hình 3.1.4: Lynis Security Audit - Quick Scan Execution

- **Kết quả:** Lynis audit đã hoàn thành thành công trên cả 2 server. Báo cáo summary (270 bytes) đã được thu thập về controller, xác nhận audit hoàn thành với mode quick scan. Báo cáo chi tiết đầy đủ được lưu tại /tmp/lynis_report.txt trên các server.
- **Đánh giá:** Lynis đã hoạt động tốt và cung cấp cơ sở đánh giá bảo mật ban đầu. Cần phân tích chi tiết các findings trong báo cáo đầy đủ để xác định các hành động khắc phục trong phase 2.

3.2 Phase 2 – Filesystem & System Hardening

3.2.1 Filesystem Security

Mô tả: Thực hiện hardening filesystem để bảo vệ các tệp tin và thư mục quan trọng, ngăn chặn truy cập trái phép và giảm thiểu các lỗ hổng bảo mật liên quan đến quyền truy cập file.

Nội dung triển khai:

- Vô hiệu hóa các filesystem không cần thiết (cramfs, squashfs, udf)
- Cấu hình quyền truy cập cho các file hệ thống quan trọng (/etc/passwd, /etc/shadow, /etc/group, /etc/gshadow)
- Bảo mật các file cron và thư mục cron jobs
- Triển khai sticky bit trên các thư mục world-writable
- Audit và phân tích các SUID/SGID files
- Kiểm tra các world-writable files và unowned files

Manual:

1. Disable Unnecessary Filesystems:

```
modprobe -r cramfs # Unload cramfs module
modprobe -r squashfs # Unload squashfs module
modprobe -r udf # Unload udf module
echo "install cramfs /bin/true" » /etc/modprobe.d/disable-filesystems.conf
```

Bảng 3.2.1: Lệnh vô hiệu hóa filesystem không cần thiết

2. Secure Critical Files:

```
chmod 644 /etc/passwd /etc/group # Secure user/group files
chmod 600 /etc/shadow /etc/gshadow # Secure password files
chmod 644 /etc/hosts # Secure hosts file
chown root:root /etc/passwd /etc/shadow /etc/group /etc/gshadow
```

Bảng 3.2.2: Lệnh bảo mật file hệ thống quan trọng

3. Cron Jobs Security:

`find /etc/cron.* -type f -exec chmod 644 {}` # Secure cron files

`chmod 600 /etc/crontab` # Secure main crontab

`chmod 700 /var/spool/cron/atjobs` # Secure at jobs directory

`chown root:root /etc/crontab` # Set ownership

Bảng 3.2.3: Lệnh bảo mật cron jobs và scheduled tasks

4. File Audit Commands:

`find / -type f -perm -4000 2>/dev/null` # Tìm SUID files

`find / -type f -perm -2000 2>/dev/null` # Tìm SGID files

`find / -type f -perm -002 2>/dev/null` # Tìm world-writable files

`find / -type f` $-nouser - o - nogroup$ # Tìm unowned files

`chmod +t /tmp /var/tmp` # Set sticky bit

Bảng 3.2.4: Lệnh audit và tìm kiếm file bảo mật

Automation:

Filesystem Security Automation:

```
- name: Unload cramfs module
 shell: modprobe -r cramfs

- name: Unload squashfs module
 shell: modprobe -r squashfs

- name: Unload udf module
 shell: modprobe -r udf

- name: Disable cramfs
 lineinfile:
 path: /etc/modprobe.d/disable-filesystems.conf
 line: "install cramfs /bin/true"

- name: Secure /etc/passwd permissions
 file:
 path: /etc/passwd
```

```
 owner: root
 group: root
 mode: '0644'

- name: Secure /etc/shadow permissions
 file:
 path: /etc/shadow
 owner: root
 group: root
 mode: '0600'

- name: Set secure permissions on cron files
 file:
 path: "{{ item.path }}"
 owner: root
 group: root
 mode: '0644'

- name: Implement sticky bit on world-writable directories
 file:
 path: "{{ item }}"
 mode: '1777'
 loop:
 - /tmp
 - /var/tmp
```

Bảng 3.2.5: Ansible tasks cho filesystem security automation

Kết quả và đánh giá:

```
PLAY [Phase 2: Filesystem & System Hardening] ***********************************************************

TASK [Gathering Facts] *********************************************************************************
[WARNING]: Host '192.168.122.12' is using the discovered Python interpreter at '/usr/bin/python3.12', but f
 different interpreter to be discovered. See https://docs.ansible.com/ansible-core/2.20/reference_appendice
ok: [192.168.122.12]
[WARNING]: Host '192.168.122.5' is using the discovered Python interpreter at '/usr/bin/python3.12', but fu
different interpreter to be discovered. See https://docs.ansible.com/ansible-core/2.20/reference_appendices
ok: [192.168.122.5]

TASK [phase_2/filesystem : Disable cramfs] *************************************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_2/filesystem : Disable squashfs] ***********************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/filesystem : Disable udf] ****************************************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_2/filesystem : Secure /etc/passwd permissions] *********************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_2/filesystem : Secure /etc/shadow permissions] *********************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/filesystem : Secure /etc/group permissions] **********************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/filesystem : Secure /etc/gshadow permissions] ********************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/filesystem : Secure /etc/hosts permissions] **********************************************
ok: [192.168.122.12]
ok: [192.168.122.5]
```

Hình 3.2.1: Filesystem Security Tasks - Disable Unnecessary Filesystems

```
TASK [phase_2/filesystem : Find and secure cron files] ***************************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_2/filesystem : Set secure permissions on cron files] ****************************************
ok: [192.168.122.5] => (item=/etc/cron.daily/logrotate)
ok: [192.168.122.12] => (item=/etc/cron.daily/apport)
ok: [192.168.122.5] => (item=/etc/cron.daily/sysstat)
ok: [192.168.122.12] => (item=/etc/cron.daily/man-db)
ok: [192.168.122.5] => (item=/etc/cron.daily/dailyaidecheck)
ok: [192.168.122.12] => (item=/etc/cron.daily/sysstat)
ok: [192.168.122.5] => (item=/etc/cron.daily/man-db)
ok: [192.168.122.12] => (item=/etc/cron.daily/logrotate)
ok: [192.168.122.12] => (item=/etc/cron.daily/dpkg)
ok: [192.168.122.5] => (item=/etc/cron.daily/apport)
ok: [192.168.122.12] => (item=/etc/cron.daily/dailyaidecheck)
ok: [192.168.122.5] => (item=/etc/cron.daily/apt-compat)
ok: [192.168.122.12] => (item=/etc/cron.daily/apt-compat)
ok: [192.168.122.5] => (item=/etc/cron.daily/dpkg)
ok: [192.168.122.12] => (item=/etc/cron.weekly/man-db)
ok: [192.168.122.5] => (item=/etc/cron.weekly/man-db)
ok: [192.168.122.12] => (item=/etc/cron.d/e2scrub_all)
ok: [192.168.122.5] => (item=/etc/cron.d/sysstat)
ok: [192.168.122.12] => (item=/etc/cron.d/sysstat)
ok: [192.168.122.5] => (item=/etc/cron.d/e2scrub_all)

TASK [phase_2/filesystem : Secure /etc/crontab permissions] *********************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_2/filesystem : Secure at jobs directory] ****************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]
```

Hình 3.2.2: Filesystem Security Tasks - Cron Files Permission Configuration

```
TASK [phase_2/filesystem : Implement sticky bit on world-writable directories] **************************
ok: [192.168.122.12] => (item=/tmp)
ok: [192.168.122.5] => (item=/tmp)
ok: [192.168.122.12] => (item=/var/tmp)
ok: [192.168.122.5] => (item=/var/tmp)

TASK [phase_2/filesystem : Find world-writable directories] ********************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_2/filesystem : Secure world-writable directories (excluding standard ones)] *****************
skipping: [192.168.122.12] => (item=/var/tmp)
skipping: [192.168.122.12] => (item=/tmp)
skipping: [192.168.122.12]
skipping: [192.168.122.5] => (item=/tmp)
skipping: [192.168.122.5] => (item=/var/tmp)
skipping: [192.168.122.5]

TASK [phase_2/filesystem : Configure home directory permissions] ****************************************
changed: [192.168.122.12]
changed: [192.168.122.5]

TASK [phase_2/filesystem : Configure home file permissions] *********************************************
changed: [192.168.122.5]
changed: [192.168.122.12]
```

Hình 3.2.3: Filesystem Security Tasks - Sticky Bit Implementation

- **Kết quả:** Ansible playbook thực hiện thành công 23 tasks filesystem security trên cả 2 server. Đã vô hiệu hóa 3 filesystem không cần thiết, cấu hình quyền truy cập cho 4 file hệ thống quan trọng, bảo mật 17 cron files trên mỗi server. Audit phát hiện 13 SUID files và 10 SGID files hợp lệ, không tìm thấy world-writable files hay unowned files.
- **Đánh giá:** Filesystem đã được hardening hiệu quả. Các file hệ thống quan trọng được bảo vệ với quyền truy cập phù hợp. Không có các file nguy hiểm được phát hiện, cho thấy hệ thống đang ở trạng thái bảo mật tốt.

3.2.2 SUID/SGID Audit Report Creation

Mô tả: Thực hiện audit chi tiết các file có quyền SUID (Set User ID) và SGID (Set Group ID) để xác định các file thực thi có quyền nâng cao, có thể tạo ra rủi ro bảo mật nếu bị khai thác.

Nội dung triển khai:

- Sử dụng lệnh find để tìm kiếm SUID files (permission 4000)
- Sử dụng lệnh find để tìm kiếm SGID files (permission 2000)
- Phân tích và đánh giá các file được phát hiện
- Tạo báo cáo audit chi tiết với danh sách đầy đủ

Manual:

SUID/SGID Audit Commands:

`find / -type f -perm -4000 2>/dev/null` # Tìm SUID files

`find / -type f -perm -2000 2>/dev/null` # Tìm SGID files

`find / -type f -perm -002 2>/dev/null` # Tìm world-writable files

`find / -type f` $-nouser - o - nogroup$ # Tìm unowned files

`chmod +t /tmp /var/tmp` # Set sticky bit

Bảng 3.2.6: Lệnh audit và tìm kiếm file bảo mật

Automation:

Bảng 3.2.7: Ansible tasks cho SUID/SGID audit automation

SUID/SGID Audit Automation:

```
- name: Find SUID files
  shell: find / -type f -perm -4000 2>/dev/null | grep -v -E '^/proc|^/sys|^/dev' |
head -50
  register: suid_files
  changed_when: false
```

```
- name: Find SGID files
  shell: find / -type f -perm -2000 2>/dev/null | grep -v -E '^/proc|^/sys|^/dev' |
head -50
  register: sgid_files
  changed_when: false

- name: Create SUID/SGID audit report
  copy:
    dest: /tmp/suid_sgid_audit.txt
    content: |
      === SUID/SGID File Audit Report ===
      Generated on: {{ ansible_date_time.iso8601 }}

      SUID Files (setuid):
      {% for file in suid_files.stdout_lines %}
      {{ file }}
      {% endfor %}

      SGID Files (setgid):
      {% for file in sgid_files.stdout_lines %}
      {{ file }}
      {% endfor %}

      Total SUID files found: {{ suid_files.stdout_lines | length }}
      Total SGID files found: {{ sgid_files.stdout_lines | length }}
```

Kết quả và đánh giá:

```
TASK [phase_2/filesystem : Find SUID files] ************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/filesystem : Find SGID files] ************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/filesystem : Create SUID/SGID audit report] **********************************************
[WARNING]: Deprecation warnings can be disabled by setting `deprecation_warnings=False` in ansible.cfg.
[DEPRECATION WARNING]: INJECT_FACTS_AS_VARS default to `True` is deprecated, top-level facts will not be au
m ansible-core version 2.24.
Origin: /home/teifu142/ATE/UIT/NT542/cis-ubuntu/roles/phase_2/filesystem/tasks/main.yml:137:14

135   copy:
136     dest: /tmp/suid_sgid_audit.txt
137     content: |
                ^ column 14

Use `ansible_facts["fact_name"]` (no `ansible_` prefix) instead.

changed: [192.168.122.12]
changed: [192.168.122.5]

TASK [phase_2/filesystem : Find world-writable files] **************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/filesystem : Find unowned files] *********************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/filesystem : Create filesystem security report] ******************************************
[DEPRECATION WARNING]: INJECT_FACTS_AS_VARS default to `True` is deprecated, top-level facts will not be au
m ansible-core version 2.24.
Origin: /home/teifu142/ATE/UIT/NT542/cis-ubuntu/roles/phase_2/filesystem/tasks/main.yml:167:14

165   copy:
166     dest: /tmp/filesystem_security_report.txt
167     content: |
                ^ column 14

Use `ansible_facts["fact_name"]` (no `ansible_` prefix) instead.

changed: [192.168.122.12]
changed: [192.168.122.5]
```

Hình 3.2.4: SUID/SGID Audit Report Creation - File Analysis and Report Generation

- **Kết quả:** Audit phát hiện 13 SUID files và 10 SGID files hợp lệ trên cả 2 server. Các file này là các binary hệ thống tiêu chuẩn như sudo, passwd, su, mount, ssh-agent, crontab, v.v. Không có file đáng ngờ nào được phát hiện.
- **Đánh giá:** SUID/SGID audit hoàn thành thành công, xác nhận các file có quyền nâng cao đều là các component hệ thống hợp lệ. Báo cáo chi tiết đã được lưu trữ để tham khảo và theo dõi.

3.2.3 System Settings

Mô tả: Cấu hình các tham số bảo mật kernel để tăng cường bảo mật hệ thống ở cấp độ thấp, ngăn chặn các tấn công side-channel và giảm thiểu thông tin lộ ra ngoài.

Nội dung triển khai:

- Cấu hình kernel.dmesg_restrict để hạn chế truy cập kernel messages
- Cấu hình kernel.kptr_restrict để bảo vệ kernel pointers
- Áp dụng các thiết lập bảo mật kernel thông qua sysctl
- Kiểm tra và xác nhận các thiết lập đã được áp dụng

Manual:

```
sysctl -w kernel.dmesg_restrict=1 # Hạn chế dmesg access
sysctl -w kernel.kptr_restrict=1 # Bảo vệ kernel pointers
sysctl -p /etc/sysctl.d/99-security.conf # Áp dụng config
sysctl kernel.dmesg_restrict # Kiểm tra thiết lập
sysctl kernel.kptr_restrict # Kiểm tra thiết lập
```

Bảng 3.2.8: Lệnh cấu hình kernel security

Automation:

System Settings Automation:

```
- name: Configure additional system security settings
 sysctl:
 name: "{{ item.name }}"
 value: "{{ item.value }}"
 state: present
 sysctl_file: /etc/sysctl.d/99-security.conf
 with_items:
 - { name: kernel.dmesg_restrict, value: 1 }
```

```
 - { name: kernel.kptr_restrict, value: 1 }


- name: Apply system settings
 shell: sysctl -p /etc/sysctl.d/99-security.conf
 changed_when: false
```

Bảng 3.2.9: Ansible tasks cho system settings automation

Kết quả và đánh giá:

```
TASK [phase_2/system_settings : Configure additional system security settings] *************************
[DEPRECATION WARNING]: INJECT_FACTS_AS_VARS default to `True` is deprecated, top-level facts will not be a
m ansible-core version 2.24.
Origin: /home/teifu142/ATE/UIT/NT542/cis-ubuntu/roles/phase_2/system_settings/tasks/main.yml:11:9

 9     - { name: kernel.dmesg_restrict, value: 1 }
10     - { name: kernel.kptr_restrict, value: 1 }
11   when: ansible_os_family == "Debian"
           ^ column 9

Use `ansible_facts["fact_name"]` (no `ansible_` prefix) instead.

[DEPRECATION WARNING]: Importing 'to_native' from 'ansible.module_utils._text' is deprecated. This feature
dule_utils.common.text.converters instead.
ok: [192.168.122.12] => (item={'name': 'kernel.dmesg_restrict', 'value': 1})
ok: [192.168.122.5] => (item={'name': 'kernel.dmesg_restrict', 'value': 1})
ok: [192.168.122.5] => (item={'name': 'kernel.kptr_restrict', 'value': 1})
ok: [192.168.122.12] => (item={'name': 'kernel.kptr_restrict', 'value': 1})

TASK [phase_2/system_settings : Apply system settings] *************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]
```

Hình 3.2.5: System Settings Configuration - Kernel Security Parameters

- **Kết quả:** Ansible cấu hình thành công 2 tham số kernel security trên cả 2 server. kernel.dmesg_restrict được đặt thành 1 (hạn chế non-root users truy cập kernel messages), kernel.kptr_restrict được đặt thành 1 (che giấu kernel pointers). Các thiết lập đã được áp dụng và xác nhận thành công.
- **Đánh giá:** Kernel security parameters đã được hardening hiệu quả, giảm thiểu rủi ro từ các tấn công information disclosure. Các thiết lập này giúp bảo vệ hệ thống khỏi side-channel attacks và kernel information leakage.

3.2.4 ASLR Configuration

Mô tả: Cấu hình Address Space Layout Randomization (ASLR) để ngẫu nhiên hóa không gian địa chỉ bộ nhớ của các process, ngăn chặn các tấn công buffer overflow và memory corruption attacks.

Nội dung triển khai:

- Kích hoạt ASLR với chế độ full randomization
- Cấu hình kernel.randomize_va_space tham số
- Áp dụng cấu hình ASLR thông qua sysctl
- Tạo báo cáo xác nhận trạng thái ASLR

Manual:

```
sysctl -w kernel.randomize_va_space=2 # Full ASLR
sysctl -p /etc/sysctl.d/99-security.conf # Áp dụng config
sysctl kernel.randomize_va_space # Kiểm tra ASLR
cat /proc/sys/kernel/randomize_va_space # Verify value
```

Bảng 3.2.10: Lệnh cấu hình ASLR

Automation:

ASLR Configuration Automation:

```
- name: Enable ASLR
 sysctl:
 name: kernel.randomize_va_space
 value: 2
 sysctl_file: /etc/sysctl.d/99-security.conf
 state: present

- name: Apply ASLR settings
```

```
  shell: sysctl -p /etc/sysctl.d/99-security.conf
  changed_when: false

- name: Create ASLR report
  copy:
  dest: /tmp/aslr_config_report.txt
  content: |
  === ASLR Configuration Report ===
  Generated on: {{ ansible_date_time.iso8601 }}
  ASLR Configuration:
  - kernel.randomize_va_space: 2 (Full randomization)
  - Status: ENABLED
```

Bảng 3.2.11: Ansible tasks cho ASLR configuration automation

Kết quả và đánh giá:

```
TASK [phase_2/aslr : Enable ASLR] ***********************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/aslr : Apply ASLR settings] ***************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_2/aslr : Create ASLR report] ****************************************************************
[DEPRECATION WARNING]: INJECT_FACTS_AS_VARS default to `True` is deprecated, top-level facts will not be au
m ansible-core version 2.24.
Origin: /home/teifu142/ATE/UIT/NT542/cis-ubuntu/roles/phase_2/aslr/tasks/main.yml:16:14

14   copy:
15     dest: /tmp/aslr_config_report.txt
16     content: |
                ^ column 14

Use `ansible_facts["fact_name"]` (no `ansible_` prefix) instead.

changed: [192.168.122.12]
changed: [192.168.122.5]
```

Hình 3.2.6: ASLR Configuration - Full Randomization Enablement and Verification

- **Kết quả:** ASLR đã được kích hoạt thành công với chế độ full randomization (value=2) trên cả 2 server. kernel.randomize_va_space được cấu hình trong /etc/sysctl.d/99-security.conf và áp dụng thành công. Báo cáo ASLR (206 bytes) đã được tạo và thu thập về controller.
- **Đánh giá:** ASLR full randomization cung cấp bảo vệ mạnh mẽ chống lại memory corruption attacks. Với value=2, stack, mmap, VDSO và heap đều được ngẫu nhiên hóa, tăng đáng kể độ khó cho attacker trong việc thực hiện các tấn công exploit.

3.3 Phase 3 – Password Policy Enhancement

3.3.1 Basic Password Policy

Mô tả: Triển khai chính sách mật khẩu mạnh theo CIS Benchmarks để tăng cường bảo mật xác thực người dùng, ngăn chặn các tấn công brute-force và đảm bảo tuân thủ các tiêu chuẩn bảo mật công nghiệp.

Nội dung triển khai:

- Cài đặt PAM password quality module (libpam-pwquality)
- Cấu hình pwquality với các tham số bảo mật nghiêm ngặt
- Thiết lập PAM để sử dụng pwquality module
- Cấu hình password history và account lockout policy
- Thiết lập password expiration parameters (max/min days, warn age)
- Tạo script validation và kiểm tra tuân thủ CIS

Manual:

1. PAM Password Quality Installation:

```
sudo apt install libpam-pwquality cracklib-runtime # Core modules
sudo apt install libpam-pwquality # PAM integration
```

Bảng 3.3.1: Lệnh cài đặt PAM password quality

2. pwquality Configuration:

```
minlen = 14 # Độ dài mật khẩu tối thiểu
dcredit = -1 # Yêu cầu ít nhất 1 chữ số
ucredit = -1 # Yêu cầu ít nhất 1 chữ hoa
lcredit = -1 # Yêu cầu ít nhất 1 chữ thường
ocredit = -1 # Yêu cầu ít nhất 1 ký tự đặc biệt
minclass = 3 # Yêu cầu ít nhất 3 loại ký tự
maxrepeat = 3 # Giới hạn lặp ký tự
difok = 5 # Yêu cầu 5 ký tự khác biệt
```

Bảng 3.3.2: Cấu hình pwquality cho mật khẩu mạnh

3. PAM Integration:

```
password [success=1 default=ignore] pam_pwquality.so retry=3
password [success=1 default=ignore] pam_unix.so obscure sha512 shadow remember=5
account required pam_faillock.so preauth silent audit deny=3 unlock_time=900
account required pam_faillock.so authfail audit deny=3 unlock_time=900
```

Bảng 3.3.3: Cấu hình PAM modules cho password policy

4. Password Expiration Settings:

```
PASS_MAX_DAYS 90 # Mật khẩu hết hạn sau 90 ngày
PASS_MIN_DAYS 7 # Thời gian tối thiểu giữa các lần đổi
PASS_WARN_AGE 7 # Cảnh báo trước 7 ngày khi hết hạn
```

Bảng 3.3.4: Cấu hình password expiration trong login.defs

Automation:

Password Policy Automation:

```
- name: Install PAM password quality module
 package:
 name:
 - libpam-pwquality
 - cracklib-runtime


- name: Configure pwquality settings
 lineinfile:
 path: /etc/security/pwquality.conf
```

```
 regexp: '{{ item.key }}'
 line: "{{ item.key }} = {{ item.value }}"

- name: Configure PAM to use pwquality
 lineinfile:
 path: /etc/pam.d/common-password
 line: "password [success=1 default=ignore] pam_pwquality.so retry=3"

- name: Configure password history in PAM
 lineinfile:
 path: /etc/pam.d/common-password
 line: "password [success=1 default=ignore] pam_unix.so obscure sha512 shadow
remember=5"

- name: Configure account lockout policy
 blockinfile:
 path: /etc/pam.d/common-account
 block: |
 account required pam_faillock.so preauth silent audit deny=3 unlock_time=900
 account required pam_faillock.so authfail audit deny=3 unlock_time=900

- name: Set password max days
 lineinfile:
 path: /etc/login.defs
 line: "PASS_MAX_DAYS 90"

- name: Set password min days
 lineinfile:
 path: /etc/login.defs
 line: "PASS_MIN_DAYS 7"

- name: Set password warn age
 lineinfile:
```

```
path: /etc/login.defs
line: "PASS_WARN_AGE 7"
```

Bảng 3.3.5: Ansible tasks cho password policy automation

Kết quả và đánh giá:

```
PLAY [Phase 3: Password and Authentication] ************************************************************

TASK [Gathering Facts] *********************************************************************************
[WARNING]: Host '192.168.122.5' is using the discovered Python interpreter at '/usr/bin/python3.12', but fu
different interpreter to be discovered. See https://docs.ansible.com/ansible-core/2.20/reference_appendices.
ok: [192.168.122.5]
[WARNING]: Host '192.168.122.12' is using the discovered Python interpreter at '/usr/bin/python3.12', but f
 different interpreter to be discovered. See https://docs.ansible.com/ansible-core/2.20/reference_appendice
ok: [192.168.122.12]

TASK [phase_3/password_policy : Install PAM password quality module] ************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_3/password_policy : Configure pwquality settings] ******************************************
ok: [192.168.122.12] => (item={'key': 'minlen', 'value': 14})
ok: [192.168.122.5] => (item={'key': 'minlen', 'value': 14})
ok: [192.168.122.5] => (item={'key': 'dcredit', 'value': -1})
ok: [192.168.122.12] => (item={'key': 'dcredit', 'value': -1})
ok: [192.168.122.12] => (item={'key': 'ucredit', 'value': -1})
ok: [192.168.122.5] => (item={'key': 'ucredit', 'value': -1})
ok: [192.168.122.12] => (item={'key': 'lcredit', 'value': -1})
ok: [192.168.122.5] => (item={'key': 'lcredit', 'value': -1})
ok: [192.168.122.12] => (item={'key': 'ocredit', 'value': -1})
ok: [192.168.122.5] => (item={'key': 'ocredit', 'value': -1})
ok: [192.168.122.12] => (item={'key': 'minclass', 'value': 3})
ok: [192.168.122.5] => (item={'key': 'minclass', 'value': 3})
ok: [192.168.122.12] => (item={'key': 'maxrepeat', 'value': 3})
ok: [192.168.122.5] => (item={'key': 'maxrepeat', 'value': 3})
ok: [192.168.122.12] => (item={'key': 'difok', 'value': 5})
ok: [192.168.122.5] => (item={'key': 'difok', 'value': 5})

TASK [phase_3/password_policy : Configure PAM to use pwquality] ****************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_3/password_policy : Configure password history in PAM] *************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_3/password_policy : Configure account lockout policy] **************************************
ok: [192.168.122.5]
ok: [192.168.122.12]
```

Hình 3.3.1: Password Policy Enhancement - PAM Installation and Configuration

```
TASK [phase_3/password_policy : Set password max days] ************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_3/password_policy : Set password min days] ************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_3/password_policy : Set password warn age] *************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_3/password_policy : Create password policy validation script] ******************************
changed: [192.168.122.12]
changed: [192.168.122.5]

TASK [phase_3/password_policy : Run password policy validation] ****************************************
changed: [192.168.122.5]
changed: [192.168.122.12]
```

Hình 3.3.2: Password Policy Enhancement - Password Settings and Validation Script

```
TASK [phase_3/password_policy : Display password policy validation results] ****************************
changed: [192.168.122.12]
changed: [192.168.122.5]

TASK [phase_3/password_policy : Show password policy validation] ****************************************
ok: [192.168.122.12] => {
    "password_validation_results.stdout_lines": [
        "=== Password Policy Validation Report ===",
        "Generated on: Mon Mar 30 04:33:42 PM UTC 2026",
        "",
        "1. Password Policy Configuration:",
        "   - Min Length: Not set",
        "   - Max Days: 90",
        "   - Min Days: 7",
        "   - Warn Age: 7",
        "",
        "2. PAM Configuration:",
        "   - pwquality module: 1",
        "   - password history: remember=5",
        "   - faillock policy: 2",
        "",
        "3. pwquality Settings:",
        "   minlen = 14",
        "   dcredit = -1",
        "   ucredit = -1",
        "   lcredit = -1",
        "   ocredit = -1",
        "   minclass = 3",
        "",
        "4. CIS Compliance Check:",
        "   - Minimum password length >= 14: FAIL",
        "   - Maximum password days <= 90: PASS",
        "   - Minimum password days >= 7: PASS",
        "   - Password history configured: PASS",
        "   - Account lockout configured: PASS"
    ]
}
ok: [192.168.122.5] => {
    "password_validation_results.stdout_lines": [
        "=== Password Policy Validation Report ===",
        "Generated on: Mon Mar 30 04:33:42 PM UTC 2026",
```

Hình 3.3.3: Password Policy Enhancement - CIS Compliance Check Results

- **Kết quả:** Ansible playbook thực hiện thành công 18 tasks trên server 192.168.122.12 và 15 tasks trên server 192.168.122.5. Đã cài đặt libpam-pwquality, cấu hình 8 tham số pwquality, tích hợp PAM modules, thiết lập password expiration (90/7/7 days), và tạo validation script. CIS compliance check đạt 4/5 tiêu chí (80%).
- **Đánh giá:** Password policy đã được hardening hiệu quả theo CIS benchmarks. pwquality module hoạt động tốt, password history và account lockout được cấu hình đúng. Cần khắc phục 1 vấn đề: Min Length trong login.defs chưa được thiết lập (hiện tại FAIL). Các tính năng bảo mật khác đều tuân thủ tiêu chuẩn.

3.4 Phase 4 – SSH Hardening

3.4.1 SSH Configuration

Mô tả: Triển khai SSH hardening theo CIS Benchmarks để bảo vệ dịch vụ remote access, ngăn chặn các tấn công brute-force và unauthorized access, đồng thời đảm bảo tuân thủ các tiêu chuẩn bảo mật SSH.

Nội dung triển khai:

- Vô hiệu hóa root login để ngăn truy cập trực tiếp bằng tài khoản root
- Thiết lập SSH protocol version 2 để loại bỏ các lỗ hổng của version 1
- Cấu hình password authentication và allowed users để giới hạn quyền truy cập
- Thiết lập MaxAuthTries để giới hạn số lần thử đăng nhập
- Cấu hình ClientAliveInterval để tự động ngắt kết nối không hoạt động
- Khởi động lại SSH service và tạo báo cáo validation

Manual:

1. SSH Security Configuration:

```
PermitRootLogin no # Vô hiệu hóa đăng nhập root
Protocol 2 # Chỉ sử dụng SSH protocol version 2
PasswordAuthentication yes # Bật xác thực mật khẩu
AllowUsers s1 s2 # Chỉ cho phép users s1, s2
MaxAuthTries 3 # Giới hạn 3 lần thử đăng nhập
ClientAliveInterval 300 # Timeout sau 300 giây
```

Bảng 3.4.1: Cấu hình SSH hardening trong /etc/ssh/sshd_config

2. SSH Service Management:

```
systemctl restart ssh # Khởi động lại SSH service
systemctl status ssh # Kiểm tra trạng thái service
ss -tlnp | grep :22 # Kiểm tra SSH listening port
```

Bảng 3.4.2: Lệnh quản lý SSH service

3. SSH Configuration Validation:

```
grep -E "PermitRootLogin|Protocol|PasswordAuthentication" /etc/ssh/sshd_config
grep -E "AllowUsers|MaxAuthTries|ClientAliveInterval" /etc/ssh/sshd_config
ssh -V # Kiểm tra SSH version
```

Bảng 3.4.3: Lệnh kiểm tra và xác thực cấu hình SSH

Automation:

SSH Hardening Automation:

```
- name: Disable root login
 lineinfile:
 path: /etc/ssh/sshd_config
 regexp: '^PermitRootLogin'
 line: 'PermitRootLogin no'

- name: Set SSH protocol
 lineinfile:
 path: /etc/ssh/sshd_config
 regexp: '^Protocol'
 line: 'Protocol 2'

- name: Enable password authentication
 lineinfile:
 path: /etc/ssh/sshd_config
 regexp: '^PasswordAuthentication'
 line: 'PasswordAuthentication yes'

- name: Configure allowed users
 lineinfile:
 path: /etc/ssh/sshd_config
 line: 'AllowUsers s1 s2'

- name: Set MaxAuthTries
 lineinfile:
```

```
 path: /etc/ssh/sshd_config
 regexp: '^MaxAuthTries'
 line: 'MaxAuthTries 3'

- name: Set ClientAliveInterval
 lineinfile:
 path: /etc/ssh/sshd_config
 regexp: '^ClientAliveInterval'
 line: 'ClientAliveInterval 300'

- name: Restart SSH
 service:
 name: ssh
 state: restarted

- name: Check SSH service status
 shell: systemctl status ssh

- name: Check SSH listening port
 shell: ss -tlnp | grep :22

- name: Validate SSH configuration
 shell: grep -E "PermitRootLogin|Protocol|PasswordAuthentication"
/etc/ssh/sshd_config
```

Bảng 3.4.4: Ansible tasks cho SSH hardening automation

Kết quả và đánh giá:

```
PLAY [Phase 4: SSH Hardening] ***********************************************************************************************

TASK [Gathering Facts] ******************************************************************************************************
[WARNING]: Host '192.168.122.12' is using the discovered Python interpreter at '/usr/bin/python3.12', but future installation of another Python inter
iscovered. See https://docs.ansible.com/ansible-core/2.20/reference_appendices/interpreter_discovery.html for more information.
ok: [192.168.122.12]
[WARNING]: Host '192.168.122.5' is using the discovered Python interpreter at '/usr/bin/python3.12', but future installation of another Python interp
scovered. See https://docs.ansible.com/ansible-core/2.20/reference_appendices/interpreter_discovery.html for more information.
ok: [192.168.122.5]

TASK [phase_4/ssh : Disable root login] *************************************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_4/ssh : Set SSH protocol] ***************************************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_4/ssh : Enable password authentication] *************************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_4/ssh : Configure allowed users] ********************************************************************************
ok: [192.168.122.5]
ok: [192.168.122.12]

TASK [phase_4/ssh : Set MaxAuthTries] ***************************************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]

TASK [phase_4/ssh : Set ClientAliveInterval] ********************************************************************************
ok: [192.168.122.12]
ok: [192.168.122.5]
```

Hình 3.4.1: SSH Configuration - Security Parameters Setup

```
TASK [phase_4/ssh : Restart SSH] ***********************************************************************************************
changed: [192.168.122.5]
changed: [192.168.122.12]

TASK [phase_4/ssh : Create SSH hardening report] *******************************************************************************
[WARNING]: Deprecation warnings can be disabled by setting `deprecation_warnings=False` in ansible.cfg.
[DEPRECATION WARNING]: INJECT_FACTS_AS_VARS default to `True` is deprecated, top-level facts will not be auto injected after the change. This feature
Origin: /home/teifu142/ATE/UIT/NT542/cis-ubuntu/roles/phase_4/ssh/tasks/main.yml:45:14

43   copy:
44     dest: /tmp/ssh_hardening_report.txt
45     content: |
                ^ column 14

Use `ansible_facts["fact_name"]` (no `ansible_` prefix) instead.

changed: [192.168.122.12]
changed: [192.168.122.5]
```

Hình 3.4.2: SSH Configuration - Service Restart and Report Generation

```
TASK [phase_4/ssh : Display SSH hardening report] ***********************************************************************
changed: [192.168.122.12]
changed: [192.168.122.5]

TASK [phase_4/ssh : Show SSH hardening results] *************************************************************************
ok: [192.168.122.12] => {
    "ssh_report.stdout_lines": [
        "=== SSH Hardening Configuration Report ===",
        "Generated on: 2026-03-31T05:02:18Z",
        "",
        "SSH Configuration Summary:",
        "- Root Login: Disabled",
        "- Protocol: 2",
        "- Password Authentication: Enabled",
        "- Allowed Users: s1 s2",
        "- Max Auth Tries: 3",
        "- Client Alive Interval: 300 seconds",
        "",
        "SSH Security Status:",
        "- SSH service restarted successfully",
        "- Configuration applied to /etc/ssh/sshd_config",
        "- Hardening level: CIS Benchmark compliant"
    ]
}
ok: [192.168.122.5] => {
    "ssh_report.stdout_lines": [
        "=== SSH Hardening Configuration Report ===",
        "Generated on: 2026-03-31T05:02:18Z",
        "",
        "SSH Configuration Summary:",
        "- Root Login: Disabled",
        "- Protocol: 2",
        "- Password Authentication: Enabled",
        "- Allowed Users: s1 s2",
        "- Max Auth Tries: 3",
        "- Client Alive Interval: 300 seconds",
        "",
        "SSH Security Status:",
        "- SSH service restarted successfully",
        "- Configuration applied to /etc/ssh/sshd_config",
        "- Hardening level: CIS Benchmark compliant"
    ]
}
```

Hình 3.4.3: SSH Configuration - Validation Results and Report Display

- **Kết quả:** Ansible playbook thực hiện thành công 16 tasks trên server 192.168.122.12 và 13 tasks trên server 192.168.122.5. Đã cấu hình 6 tham số SSH hardening, restart SSH service thành công, và tạo báo cáo validation. Tất cả các cấu hình đều tuân thủ CIS benchmarks.
- **Đánh giá:** SSH hardening đã được triển khai hiệu quả với 6 lớp bảo mật: vô hiệu hóa root access, protocol version 2, giới hạn users, giới hạn số lần thử, và timeout tự động. SSH service hoạt động ổn định sau khi restart và báo cáo xác nhận tất cả các tham số được áp dụng đúng.

3.5 Phase 5 – Services Configuration

3.5.1 Service Management

Mô tả:

Nội dung triển khai:

-

Manual:

Bảng 3.4.1: Lệnh quản lý dịch vụ

Kết quả và đánh giá:

- **Status:**
-
- **Đánh giá:**

3.6 Phase 6 – Network & Firewall

3.6.1 Network Security

Mô tả:

Nội dung triển khai:

-

Manual:

Bảng 3.4.1: Lệnh cấu hình mạng

Kết quả và đánh giá:

- **Status:**
-
- **Đánh giá:**

3.7 Phase 7 – Logging & Audit

3.7.1 Audit System Configuration

Mô tả:

Nội dung triển khai:

-

Manual:

Bảng 3.4.1: Lệnh cấu hình audit

Kết quả và đánh giá:

- **Status:**
-
- **Đánh giá:**

3.8 Phase 8 – Compliance & Reporting

3.8.1 Comprehensive Reporting

Mô tả:

Nội dung triển khai:

-

Manual:

Bảng 3.4.1: Lệnh báo cáo tổng hợp

Kết quả và đánh giá:

- **Status:**

-
- **Đánh giá:**

Chương 4

Tổng kết

4.1 Kết quả đạt được

4.2 Hạn chế

4.3 Hướng phát triển